

ing encrypted between client and Web server. Between Web server and e-mail server, we can have SSL-enabled SMTP in the form SMTPS, SSL-enabled POP3 in the form POP3S, SSL-enabled IMAP in the form IMAP3S or some other kind of security. It all depends upon the requirement and ease of usage. The above-mentioned scenarios are depicted in Fig. 2.

We have mentioned a phrase, 'some other kind of security' many a times above, but what does it mean? In the scenario of Web-based e-mail access, we can take S/MIME or MOSS as different security standards that can be used. Similarly, in the scenario of non-Web-based access, we can take PGP or PEM as some other security standards. But MOSS and PEM are not much used these days for e-mail security.

Issues in e-mail security

E-mail can be made secure, but we have to take a few things into account. The first thing to understand is that we cannot do much about the addresses, or the subject line. Nothing about these can be made secure. Different systems may allow us to secure the message text of the e-mail, but we have to be very certain what that security is, when it is added, when it is removed and how we could prove it had been secured, afterwards. These are fundamental and important if we are going to rely on the security mechanisms later as proof that something happened.

The second thing to understand is that we can never (with current systems) send anything secret to someone we do not know. It is not possible. We have to have a 'public key' of theirs before it can be done. We cannot, with conventional systems, send information to 'anyone' in a particular group, function or business. We have to send to specific individuals.

The third thing to understand is that the protection that we apply to an e-mail has to be something that the recipient can deal with. E-mail systems do not currently relate the keys

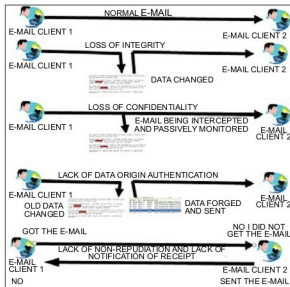


Fig. 3: Security issues in e-mail

used for information protection to the recipients of the e-mail, and do not know what algorithms the recipient is likely to have. This is because there are far too many unnecessary choices forced onto users of these systems and services (or set by administrators who are making choices based upon their own prejudices rather than looking at usability). If we use something the recipient cannot process, we are wasting time. But we cannot afford the time needed to sort this kind of problem out.

Most of the difficulties identified can be avoided by ignoring the e-mail systems completely and concentrating instead on the information to be sent. This could be anything—a word document, a text file, some HTML, a graphic or even a video. Whatever we do should not alter its content, and it should not be possible to remove your security before the information reaches securely in the computer system of the recipient.

This means that the protection software is going to protect the file in such a way that an attacker cannot remove the protection without us being able to detect it. (That is not the same as pretending a fake document is real. Since much of the information we get is not protected, today we make value judgements on what is 'right' based

upon our own feelings, or we 'phone' the sender and ask them to confirm what they actually sent. So removing the protection and making subtle changes to documents that we might then believe is perfectly feasible.) The recipient is then in a position where his/her first step is to check the authenticity of the file he/she has received. That avoids any possibility of misunderstanding what is protected and what is not. The file is the thing that is protected, and not other parts

of the e-mail, that may or may not be correct.

Once the recipient has checked that the file is authentic, he/she can go ahead and use a copy of it whose protection has been removed. This is an essential step, because he or she must not be able to alter, or add to, the file that they received and still claim that it was ever authentic (unless, of course, we have some system that maintains a copy of different things in the file, protected by each person that has altered or added to it). This approach may not seem as elegant as having everything automated, but it is a lot more secure, and prevents any mistakes or misunderstandings about who has signed what, and therefore what can be relied upon. Now let us see the various issues in e-mail security. Normally, two kinds of threats can be there in e-mail security, and these are:

Threats which can be there on the security of e-mail itself. These are the threats which can make an e-mail vulnerable. These threats are basically of five types. These are:

1. *Loss of confidentiality.* This threat arises due to lack of privacy of an e-mail, which occurs when an e-mail is sent over open networks. This threat can be removed by providing encryption over the message part. Such a message will not make any